
개인정보보호암호기술

개인정보의 개념과 보호 원칙

강원대학교 이세영



이번 시간에 다룰 내용

학습목표

01

개인정보자기결정권과 국내 개인정보 보호 법체계를 이해한다

02

국제 규범과 개인정보 보호법이 정한 보호 원칙을 설명할 수 있다

03

개인정보를 적법하게 처리하기 위한 근거와 동의 요건을 파악한다

04

정보주체의 권리와 개인정보처리자의 의무를 구분하여 설명할 수 있다

05

보호 원칙이 어떤 암호기술로 구현되는지 연결할 수 있다

Contents

01

개인정보 보호의 근거와 법체계

개인정보자기결정권, 일반법·특별법 구조, 주요 용어 정의

02

개인정보 보호 원칙

OECD 8원칙, GDPR 7원칙, 개인정보 보호법 제3조

03

적법한 처리 근거와 동의

수집·이용, 제3자 제공, 목적 외 이용, 위탁, 특별 보호 대상

04

정보주체의 권리와 처리자의 의무

열람·정정·삭제·처리정지, 처리방침, 보호책임자, 유출 통지

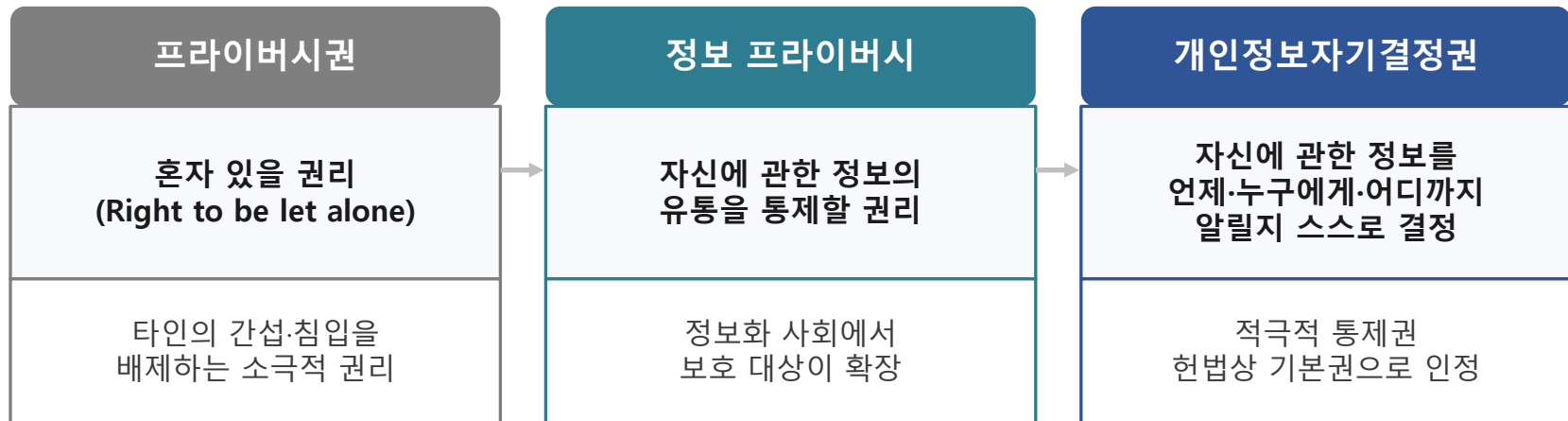
05

보호 원칙과 암호기술의 연결

Privacy by Design, 원칙별 기술 대응, 위반 시 제재

개인정보 보호의 근거

- 개인정보 보호는 "데이터 관리"가 아니라 "권리 보장"의 문제
 - 정보가 축적·결합되면 한 사람의 삶 전체가 재구성될 수 있음
 - 본인이 모르는 사이에 평가·분류·차별의 근거가 될 수 있음

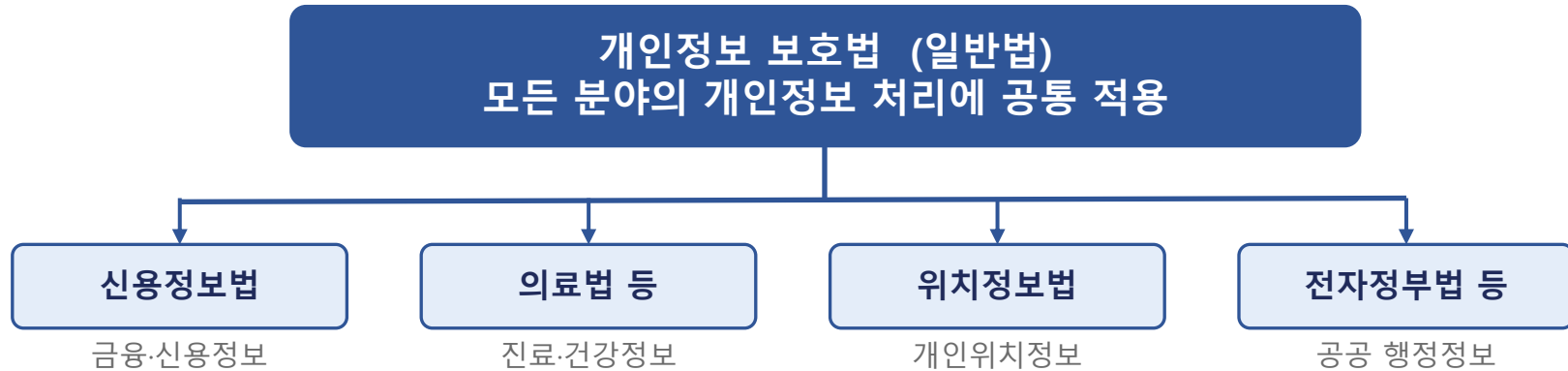


헌법재판소는 개인정보자기결정권을 헌법 제10조(인격권·행복추구권)와 제17조(사생활의 비밀과 자유)에 근거한 독자적 기본권으로 인정 (2005. 5. 26. 99헌마513 등)

- 개인정보 보호법은 이 기본권을 구체적인 절차와 의무로 제도화한 법률

국내 개인정보 보호 법체계

□ 일반법과 특별법의 구조



적용 원칙 : 특별법에 규정이 있으면 특별법 우선, 규정이 없으면 개인정보 보호법 적용

규범 단계	명칭	성격 · 내용
법률	개인정보 보호법	원칙, 권리, 의무, 제재의 기본 틀
대통령령	개인정보 보호법 시행령	법률의 위임 사항 구체화 (기준·절차·기간)
고시	개인정보의 안전성 확보조치 기준	암호화·접근통제 등 기술적 조치의 세부 기준
가이드라인	가명정보 처리 가이드라인 등	법적 구속력은 없으나 실무의 사실상 기준

- 암호화 의무의 구체적 내용은 법률이 아니라 「안전성 확보조치 기준」 고시에 규정됨

법에서 정의하는 주요 용어

용어	법적 정의 (요약)	예시
정보주체	처리되는 정보에 의하여 알아볼 수 있는 사람으로서 그 정보의 주체가 되는 사람	회원, 환자, 고객, 학생
개인정보파일	개인정보를 쉽게 검색할 수 있도록 일정한 규칙에 따라 체계적으로 배열·구성한 집합물	회원 DB, 인사기록 파일
개인정보처리자	업무를 목적으로 개인정보파일을 운용하기 위하여 스스로 또는 다른 사람을 통하여 개인정보를 처리하는 자	기업, 병원, 학교, 공공기관
처리	수집·생성·연계·연동·기록·저장·보유·가공·편집·검색·출력·정정·복구·이용·제공·공개·파기 등 그 밖에 이와 유사한 행위	DB 저장, 조회, 백업, 삭제
개인정보취급자	개인정보처리자의 지휘·감독을 받아 개인정보를 처리하는 임직원·파견근로자 등	상담원, 운영자, DBA

「처리」의 범위가 매우 넓다는 점에 주의 — 조회 · 출력 · 백업 · 파기까지 모두 규율 대상

- 법적 책임은 개인정보처리자(조직) 가 지며, 개인정보취급자는 지휘·감독의 대상
 - 따라서 조직은 취급자에 대한 교육·권한관리·접속기록 점검 의무를 부담

처리 주체의 구분

□ 누가 어떤 지위에서 개인정보를 다루는가

개인정보처리자	개인정보취급자	수탁자
처리 목적과 방법을 스스로 결정하는 주체	처리자의 지휘·감독을 받아 실제로 처리	처리 업무를 위탁받아 대신 수행하는 자
법적 책임의 귀속점 (과징금·과태료 대상)	권한 범위 내 처리 교육·감독의 대상	위탁자의 관리·감독 대상, 손해배상 시 소속 직원으로 간주

□ 실무에서 자주 혼동되는 지점

- 클라우드 사업자·고객센터 외주사·결제 대행사는 대부분 「수탁자」
 - 위탁은 처리자의 업무를 대신하는 것 → 별도의 정보주체 동의가 원칙적으로 불필요
 - 다만 위탁 사실과 수탁자를 공개해야 하며, 위탁자는 관리·감독 책임을 짐
- 제3자 제공은 상대방이 「자기 목적」으로 사용하는 것 → 원칙적으로 동의 필요
 - 판단 기준 : 처리 목적을 누가 결정하는가 (위탁자의 목적인가, 상대방의 목적인가)

국제 규범 : OECD 프라이버시 8원칙

- 1980년 OECD 이사회 권고 — 각국 개인정보 보호 법제의 원형

원칙	내용	우리 법의 대응
수집 제한	적법·공정한 수단으로, 필요한 경우 동의를 받아 수집	제3조①, 제15조
정보 정확성	이용 목적에 필요한 범위에서 정확·완전·최신 상태 유지	제3조③
목적 명확화	수집 시점에 이용 목적을 명확히 특정	제3조①, 제15조①
이용 제한	명시한 목적 외로 공개·이용·제공하지 않음	제3조②, 제18조
안전성 확보	분실·불법 접근·파괴·변조·유출 위험에 대한 합리적 보호조치	제3조④, 제29조
공개	처리 방침·정책을 일반에 공개	제3조⑤, 제30조
개인 참가	본인 정보의 존재 확인·열람·정정·삭제를 요구할 수 있음	제4조, 제35~37조
책임	관리자는 위 원칙 준수에 대한 책임을 진다	제3조⑧, 제31조

- 8원칙은 법적 구속력은 없으나, 국내법·GDPR을 포함한 대부분 법제의 뼈대가 됨

국제 규범 : GDPR 제5조 7원칙

■ EU 일반개인정보보호규정(GDPR) 이 정한 처리 원칙

① 적법성·공정성·투명성

Lawfulness, Fairness,
Transparency

적법한 근거 아래 공정하고
투명하게 처리

② 목적 제한

Purpose Limitation

특정·명시된 정당한 목적으로만
수집하고 그 범위에서 처리

③ 데이터 최소화

Data Minimisation

목적에 적절하고 관련되며
필요한 범위로 한정

④ 정확성

Accuracy

정확하게 유지하고
필요 시 지체 없이 정정·삭제

⑤ 보관기간 제한

Storage Limitation

목적 달성에 필요한 기간을
초과하여 식별 가능한 형태로
보관 금지

⑥ 무결성과 기밀성

Integrity and
Confidentiality

적절한 기술적·관리적 조치로
보안을 확보 (암호화·가명처리 포함)

⑦ 책임성 (Accountability) : 위 여섯 원칙을 준수하고,
그 준수를 「입증」할 책임을 개인정보처리자가 진다

- 준수만으로 부족하고 「증빙」까지 요구
→ 처리 기록, 영향평가, 로그 보관이 실무의 핵심이 됨

개인정보 보호법 제3조 : 보호 원칙

제3조(개인정보 보호 원칙) — 개인정보처리자가 개인정보를 처리할 때 지켜야 할 8개 항의 일반 원칙

①	목적 명확화 · 최소 수집	처리 목적을 명확히 하고, 그 목적에 필요한 범위에서 최소한의 개인정보를 적법하고 정당하게 수집
②	목적 범위 내 처리	처리 목적에 필요한 범위에서 적합하게 처리하고, 목적 외의 용도로 활용하지 않음
③	정확성 · 완전성 · 최신성	처리 목적에 필요한 범위에서 정확성·완전성·최신성이 보장되도록 함
④	안전한 관리	처리 방법·종류 등과 정보주체 권리 침해 가능성 및 위험 정도를 고려하여 안전하게 관리
⑤	공개 및 권리 보장	처리방침 등 처리에 관한 사항을 공개하고, 열람청구권 등 정보주체의 권리를 보장
⑥	사생활 침해 최소화	정보주체의 사생활 침해를 최소화하는 방법으로 처리
⑦	익명 · 가명처리	목적 달성이 가능하면 익명처리를, 익명처리로 어려우면 가명처리를 하여 처리
⑧	책임과 신뢰 확보	법령에서 규정한 책임과 의무를 준수하고 실천하여 정보주체의 신뢰를 얻도록 노력

원칙 ① 목적 명확화와 최소 수집

□ 최소 수집의 원칙 (제3조①, 제16조)

- 목적에 필요한 최소한의 개인정보만 수집해야 하며, 입증 책임은 개인정보처리자에게 있음
- **최소 정보 외의 항목 수집에 동의하지 않는다는 이유로 서비스 제공을 거부할 수 없음**

서비스 유형	필수 항목 (예)	과다 수집으로 판단될 수 있는 항목
일반 회원가입	아이디, 비밀번호, 이메일	주민등록번호, 가족관계, 학력, 결혼 여부
배송 서비스	수령인명, 주소, 연락처	생년월일, 직업, 소득 수준
이벤트 응모	연락처 (당첨 안내용)	주소, 계좌번호 (당첨 전 단계에서 수집)

□ 최소 수집을 지원하는 기술

- 식별자 대체 : 실명·주민등록번호 대신 내부 일련번호나 토큰을 사용
- 중복 확인 : 원본을 저장하지 않고 해시값만 비교하여 동일인 여부 판단
- 속성 증명 : 생년월일을 받지 않고 「성년 여부」만 확인 (영지식증명)
- **수집하지 않은 정보는 유출될 수 없음**
→ **가장 확실한 보호 수단은 「수집하지 않는 것」**

원칙 ② 목적 범위 내 처리

□ 목적 구속의 원칙 (제3조②, 제18조)

- 수집 시 고지한 목적의 범위에서만 이용해야 하며, 목적 외 이용·제공은 원칙적으로 금지
- 「가지고 있으니 써도 된다」는 논리는 성립하지 않음
— 소유의 적법성 ≠ 이용의 적법성

목적 범위 내 (적법)

- 배송을 위해 받은 주소로 물품 발송
- 회원 관리를 위해 받은 이메일로 서비스 장애 공지 발송
- 결제를 위해 받은 카드정보로 결제 처리
- 민원 처리를 위해 받은 연락처로 회신

목적 외 이용 (별도 근거 필요)

- 배송용 주소로 광고 우편물 발송
- 회원 이메일을 계열사 마케팅에 활용
- 민원 처리 연락처로 상품 판촉 전화
- 이용 기록을 인사·신용 평가에 활용
- 수집 목적과 무관한 AI 학습 데이터로 사용

□ 목적 외 이용·제공이 예외적으로 허용되는 주요 경우 (제18조②)

- 정보주체로부터 별도의 동의를 받은 경우
- 다른 법률에 특별한 규정이 있는 경우
- 명백히 정보주체·제3자의 급박한 생명·신체·재산의 이익을 위하여 필요한 경우
- 공공기관의 경우 통계작성·과학적 연구 등 법이 정한 사유 (일부는 보호위원회 심의·의결 필요)

원칙 ③ 정확성 · 완전성 · 최신성

□ 데이터 품질 원칙 (제3조③)

- 부정확한 개인정보는 그 자체로 정보주체에게 불이익을 발생시킴
 - 예) 잘못된 연체 기록으로 대출 거절, 오기된 병력으로 부적절한 처방, 동명이인 혼동으로 인한 불이익

요구 사항	의미	실무 조치
정확성	사실과 일치할 것	입력 검증, 정정 요구 처리 절차 운영
완전성	판단에 필요한 항목이 누락되지 않을 것	필수 항목 관리, 부분 데이터 사용 시 주의
최신성	현재 상태를 반영할 것	갱신 주기 설정, 장기 미이용 정보 파기·분리

정확성 원칙은 무결성(Integrity) 과 직접 연결됨
 — 데이터가 「올바른가」 뿐 아니라 「올바른 상태로 유지되고 있는가」 를 함께 요구

□ 정확성을 지키는 기술 수단

- 해시 함수 · 메시지 인증 코드 : 저장·전송 중 데이터가 변경되지 않았음을 검증
- 접속기록(로그) 의 무결성 보호 : 누가 언제 무엇을 수정했는지 추적 가능하게 유지
- 전자서명 : 데이터의 출처와 무결성을 동시에 보장하고 사후 부인을 방지

원칙 ④ 안전한 관리

□ 위험 비례의 원칙 (제3조④, 제29조)

- 처리 방법·종류, 권리 침해 가능성과 위험의 정도를 고려하여 안전하게 관리
- 모든 데이터에 동일한 수준의 보호를 적용하는 것이 아니라, 위험에 비례한 조치를 요구

정보 유형	위험 수준	요구되는 조치 수준
일반 개인정보	보통	접근통제, 접속기록 보관, 일반적 안전조치
비밀번호	높음	일방향 암호화(해시)하여 저장 — 복호화 불가
고유식별정보	매우 높음	저장·전송 시 암호화, 키 분리 보관
생체인식정보	매우 높음	암호화 저장, 원본 최소 보관, 변경 불가성 고려

□ 안전조치의 세 축 (기술적 · 관리적 · 물리적)

기술적 안전조치
암호화, 접근권한 관리, 접속기록 보관·점검, 악성프로그램 방지

관리적 안전조치
내부 관리계획 수립, 교육, 수탁자 관리·감독, 유출 대응계획

물리적 안전조치
전산실 출입통제, 보조저장매체 관리, 출력·복사 통제

원칙 ⑤⑥ 투명성과 사생활 침해 최소화

- ⑤ 공개 및 정보주체의 권리 보장 (제3조⑤, 제30조)
 - 처리 목적·항목·보유기간·제3자 제공·위탁 등을 처리방침으로 공개
 - 정보주체가 자신의 정보가 어떻게 쓰이는지 알 수 없다면 권리 행사 자체가 불가능
 - 투명성은 다른 모든 권리를 행사하기 위한 전제 조건
- ⑥ 사생활 침해를 최소화하는 방법으로 처리 (제3조⑥)
 - 같은 목적을 달성할 수 있다면 침해가 더 적은 방법을 선택해야 함

상황	침해가 큰 방법	침해가 적은 방법
연령 확인	주민등록번호 전체 수집	성년 여부만 확인 (본인확인기관 이용)
통계 분석	원본 데이터 그대로 분석	가명처리 후 분석, 집계값만 산출
접속 확인	전체 화면 녹화·상시 모니터링	필요한 항목만 로그로 기록
위치 기반 서비스	정밀 좌표를 상시 수집·보관	행정동 단위로 일반화, 필요 시점에만 수집

「할 수 있는가」가 아니라 「그 방법이 최소 침해인가」를 묻는 것이 설계의 출발점

원칙 ⑦ 익명처리 · 가명처리

제3조⑦ 개인정보처리자는 정보주체의 사생활 침해를 최소화하는 방법으로 개인정보를 처리하여야 하며, 익명처리로 목적을 달성할 수 있는 경우에는 익명에 의하여, 익명처리로 목적을 달성할 수 없는 경우에는 가명에 의하여 처리될 수 있도록 하여야 한다.

구분	원본 개인정보	가명정보	익명정보
처리 방식	식별자 그대로 유지	추가 정보를 분리 보관하고 식별자를 대체	복원이 불가능하도록 식별 요소 제거·일반화
식별 가능성	직접 식별 가능	추가 정보가 있으면 식별 가능	복원 불가 · 식별 불가
법적 지위	개인정보	개인정보 (일부 규정 적용 제외)	개인정보 아님
활용 범위	동의받은 목적 내	통계작성 · 과학적 연구 공익적 기록보존 등	제한 없음
데이터 유용성	높음	중간	낮음

- 가명정보는 여전히 개인정보 → 추가 정보의 분리 보관과 안전조치 의무가 유지됨
- 가명정보를 이용하여 특정 개인을 알아보기 위한 행위는 금지됨 (재식별 금지)

보호 원칙 비교 : OECD · GDPR · 국내법

핵심 개념	OECD 8원칙	GDPR 제5조	개인정보 보호법 제3조
적법한 수집	수집 제한	적법성·공정성·투명성	① 적법·정당한 수집
목적 특정	목적 명확화	목적 제한	① 목적 명확화
최소 수집	수집 제한	데이터 최소화	① 최소 수집
이용 제한	이용 제한	목적 제한	② 목적 외 활용 금지
데이터 품질	정보 정확성	정확성	③ 정확성·완전성·최신성
보안	안전성 확보	무결성과 기밀성	④ 안전한 관리
투명성	공개	투명성	⑤ 공개 및 권리 보장
보관 제한	(명시 없음)	보관기간 제한	⑥⑦ 최소 침해·익명/가명
책임성	책임	책임성	⑧ 책임·신뢰 확보

- 세 규범은 표현이 다를 뿐 동일한 뼈대를 공유
→ 하나를 이해하면 나머지를 읽을 수 있음

적법한 처리의 구조

□ 개인정보 처리 단계별 적용 조문

수집 · 이용	제3자 제공	목적 외 이용·제공	처리 위탁	파기
제15조	제17조	제18조	제26조	제21조
7가지 적법근거 중 하나 필요	동의 또는 수집 목적 범위 내	원칙 금지 예외 사유 한정	동의 불요 공개·감독 의무	목적 달성 시 지체 없이 파기

□ 핵심 구조 : 개인정보 처리는 「원칙적 금지, 예외적 허용」

- 법이 정한 근거가 있을 때에만 처리할 수 있으며, 근거 없는 처리는 그 자체로 위법
- 동의는 여러 적법근거 중 하나일 뿐이며, 언제나 최선의 근거인 것은 아님
 - 계약 이행이나 법령 준수로 처리 가능한 것을 동의로 받으면 오히려 혼란을 초래
 - 정보주체가 동의를 철회하면 서비스 제공 자체가 불가능해지는 문제 발생
- 각 단계마다 요구되는 근거가 다르므로, 데이터 흐름도를 그려 단계별로 점검해야 함

수집 · 이용의 적법근거 (제15조)

- 다음 중 어느 하나에 해당하는 경우 개인정보를 수집·이용할 수 있음

1	정보주체의 동의를 받은 경우	회원가입 시 마케팅 정보 수신 동의
2	법률에 특별한 규정이 있거나 법령상 의무를 준수하기 위하여 불가피한 경우	세법상 거래 기록 보관, 근로기준법상 근로자 명부
3	공공기관이 법령 등에서 정하는 소관 업무의 수행을 위하여 불가피한 경우	주민등록 사무, 조세 부과·징수
4	정보주체와 체결한 계약을 이행하거나 계약 체결 과정에서 요청에 따른 조치를 위하여 필요한 경우	물품 배송을 위한 주소 수집, 견적 요청 처리
5	명백히 정보주체 또는 제3자의 급박한 생명·신체·재산의 이익을 위하여 필요하다고 인정되는 경우	응급환자의 신원·병력 확인
6	개인정보처리자의 정당한 이익을 달성하기 위하여 필요한 경우로서 명백하게 정보주체의 권리보다 우선하는 경우	요금 정산, 부정 이용 방지, 시설 안전 관리
7	공중위생 등 공공의 안전과 안녕을 위하여 긴급히 필요한 경우	감염병 확산 방지를 위한 긴급 조치

동의의 유효 요건

□ 형식적으로 체크박스를 받았다고 해서 유효한 동의가 되는 것은 아님

자유로운 동의

동의하지 않을 자유가
실질적으로 보장되어야 함

선택 항목 미동의를 이유로
서비스 제공을 거부할 수 없음

구체적 동의

처리 목적별로 구분하여
각각 동의를 받아야 함

필수와 선택을 구분하고
마케팅 동의는 별도로 받음

고지에 기반한 동의

목적·항목·보유기간·
거부권과 불이익을 알림

동의를 받기 전에
네 가지 사항을 반드시 고지

명확한 의사표시

묵시적 동의·기본 체크는
원칙적으로 인정되지 않음

중요한 내용은 알아보기 쉽게
표시하여 명확히 확인

동의를 받을 때 반드시 알려야 할 사항 (제15조②)

- ① 개인정보의 수집·이용 목적 ② 수집하려는 개인정보의 항목
- ③ 보유 및 이용 기간 ④ 동의를 거부할 권리가 있다는 사실 및 거부 시 불이익의 내용

- 위 사항을 알리지 않거나 거짓으로 알리고 받은 동의는 유효한 동의로 인정되지 않음

제3자 제공 (제17조)

□ 제3자 제공의 의미

- 개인정보에 대한 지배·관리권이 제3자에게 이전되어, 제3자가 자신의 목적으로 이용하는 것



□ 제공 시 알려야 할 사항 (제17조②)

- ① 개인정보를 제공받는 자
- ② 제공받는 자의 이용 목적
- ③ 제공하는 개인정보의 항목
- ④ 제공받는 자의 보유·이용 기간
- ⑤ 동의를 거부할 권리가 있다는 사실 및 거부 시 불이익의 내용

구분	제3자 제공	처리 위탁
목적 결정 주체	제공받는 자 (자기 목적)	위탁자 (위탁자의 목적)
정보주체 동의	원칙적으로 필요	원칙적으로 불요
알림 방법	동의 시 5개 사항 고지	처리방침 공개 (홍보·판매 위탁은 통지)
사고 시 책임	제공받은 자가 처리자로서 책임	위탁자가 관리·감독 책임 부담
예시	제휴사 마케팅, 보험사 제공	배송사, 콜센터, 클라우드

목적 외 이용 · 제공의 제한 (제18조)

제18조① 개인정보처리자는 개인정보를 제15조제1항에 따른 범위를 초과하여 이용하거나 제17조제1항에 따른 범위를 초과하여 제3자에게 제공하여서는 아니 된다.

□ 예외적으로 허용되는 주요 사유 (제18조②)

정보주체의 별도 동의	수집 시 동의와 구분되는 목적 외 이용에 대한 별도 동의	민간 · 공공 공통
다른 법률의 특별한 규정	법률에 목적 외 이용의 근거가 명시된 경우	민간 · 공공 공통
급박한 생명·신체·재산 이익	명백히 정보주체 또는 제3자의 급박한 이익을 위하여 필요	민간 · 공공 공통
통계작성 · 과학적 연구	특정 개인을 알아볼 수 없는 형태로 제공하는 경우	공공기관 (일부 사유)
조약 이행 · 범죄 수사 등	법원 재판, 형 집행, 조약 이행에 필요한 경우	공공기관

- 공공기관이 목적 외로 이용·제공한 경우에는 그 사실을 관보 또는 인터넷 홈페이지에 게재해야 함
- 목적 외 제공 시 제공받는 자에게 이용 목적·방법 제한이나 안전조치를 요청할 수 있음

처리 위탁 (제26조)

□ 위탁자의 의무

- ① 문서에 의한 위탁 : 목적 외 처리 금지, 안전조치, 재위탁 제한, 관리·감독, 손해 배상 등을 명시
- ② 위탁 사실 공개 : 위탁하는 업무의 내용과 수탁자를 처리방침에 공개
- ③ **홍보·판매 권유 업무 위탁 시 : 정보주체에게 서면 등으로 알려야 함**
- ④ 관리·감독 : 수탁자가 개인정보를 안전하게 처리하는지 교육하고 감독
- ⑤ 재위탁 제한 : 위탁자의 동의를 받은 경우에만 재위탁 가능

수탁자가 업무와 관련하여 개인정보를 침해해 손해가 발생한 경우,
손해배상책임에서는 수탁자를 위탁자의 「소속 직원」으로 본다 (제26조⑥)

□ 실무에서 자주 발생하는 문제

- 위탁 계약서에 안전조치 항목이 없거나 형식적으로만 존재
- 수탁자에 대한 실질적 점검 없이 서류로만 관리·감독 이행
- 수탁자가 다시 재위탁하면서 위탁자가 데이터 소재를 파악하지 못함
- → **국내 대형 유출 사고의 상당수가 위탁·수탁 관리 미흡에서 발생**

특별 보호 대상의 처리 제한

구분	민감정보 (제23조)	고유식별정보 (제24조)	주민등록번호 (제24조의2)
대상	사상·신념, 노동조합·정당 가입, 정치적 견해, 건강·성생활, 유전정보, 범죄경력, 생체인식정보, 인종·민족	주민등록번호, 여권번호, 운전면허번호, 외국인등록번호	주민등록번호
처리 요건	별도 동의 또는 법령에서 요구·허용	별도 동의 또는 법령에서 구체적으로 요구·허용	동의로는 불가 법령에 구체적 근거가 있는 경우 등에 한함
안전조치	암호화 등 강화된 조치	암호화 저장, 연 1회 이상 취약점 점검 등	암호화 저장 (예외 없음)

주민등록번호는 정보주체의 동의를 받더라도 원칙적으로 처리할 수 없다
— 「동의만 받으면 된다」는 통념이 적용되지 않는 유일한 항목

□ 주민등록번호 처리가 가능한 경우

- 법률·대통령령·국회규칙 등에서 구체적으로 주민등록번호의 처리를 요구하거나 허용한 경우
- 정보주체 또는 제3자의 급박한 생명·신체·재산 이익을 위하여 명백히 필요한 경우
- 그 밖에 처리가 불가피한 경우로서 개인정보보호위원회가 고시로 정하는 경우

아동의 개인정보 보호

□ 만 14세 미만 아동의 개인정보 처리 (제22조의2)

- 법정대리인의 동의를 받아야 하며, 동의 여부를 확인하기 위해 필요한 최소한의 정보를 법정대리인의 동의 없이 수집할 수 있음
- **아동이 이해하기 쉬운 양식과 명확하고 알기 쉬운 언어로 알려야 함**

왜 별도로 보호하는가

- 동의의 의미와 결과를 충분히 판단하기 어려움
- 온라인 활동 기록이 장기간 축적되어 성인기까지 영향
- 게임 · 학습 서비스 등 아동 대상 서비스의 데이터 수집 증가

실무에서 요구되는 조치

- 연령 확인 절차 마련 (최소한의 정보만 수집)
- 법정대리인 동의 확인 방법 확보
- 아동용 처리방침 · 동의서를 쉬운 언어로 별도 제공
- 아동 대상 맞춤형 광고에 대한 신중한 접근

국제적으로도 아동은 강화된 보호 대상 — GDPR 은 정보사회서비스 이용에 관한 동의 연령을 원칙적으로 만 16세로 정하고, 회원국이 만 13세까지 낮출 수 있도록 규정

개인정보의 파기 (제21조)

- 보유기간이 지나거나 처리 목적이 달성된 경우 지체 없이 파기해야 함
 - 다른 법령에 따라 보존해야 하는 경우에는 해당 정보를 분리하여 저장·관리
 - 복구 또는 재생되지 아니하도록 조치해야 함 (단순 삭제로는 불충분)

매체 · 형태	파기 방법	주의 사항
전자적 파일	복원이 불가능한 방법으로 영구 삭제	휴지통 삭제·인덱스 제거만으로는 불충분
저장 매체	물리적 파괴, 디가우징, 완전 포맷	불용 처리·교체 시에도 파기 절차 필요
출력물 · 문서	파쇄 또는 소각	이면지 재활용 금지
암호화된 데이터	암호키를 안전하게 파기 (크립토 셰딩)	백업본의 키까지 모두 파기해야 유효

크립토 셰딩 (Crypto-shredding)

데이터를 직접 지우는 대신 복호화 키만 파기하여 데이터를 영구히 복원 불가능하게 만드는 방법
 → 분산 저장·백업이 많아 물리적 삭제가 어려운 클라우드 환경에서 특히 유용

- 장기 미이용 정보의 분리 보관·파기는 「보관기간 제한 원칙」의 직접적 이행 수단

정보주체의 권리 (제4조)

1	개인정보의 처리에 관한 정보를 제공받을 권리	알 권리 · 투명성	제20조, 제30조
2	처리에 관한 동의 여부, 동의 범위 등을 선택하고 결정할 권리	자기결정권의 핵심	제15조, 제22조
3	처리 여부를 확인하고 개인정보에 대하여 열람(사본 발급 포함) 및 전송을 요구할 권리	열람권 · 전송요구권	제35조, 제35조의2
4	처리 정지, 정정·삭제 및 파기를 요구할 권리	정정·삭제권 · 처리정지권	제36조, 제37조
5	개인정보의 처리로 인하여 발생한 피해를 신속하고 공정한 절차에 따라 구제받을 권리	피해 구제권	제39조, 분쟁조정
6	완전히 자동화된 결정에 대하여 거부하거나 그에 대한 설명 등을 요구할 권리	자동화 결정 대응권	제37조의2

권리 행사의 절차

권리	조문	내용	제한 · 거절 사유 (예)
열람 요구	제35조	자신의 개인정보에 대한 열람·사본 발급 요구	법률에 따라 열람이 금지·제한되는 경우, 타인의 생명·신체를 해칠 우려가 있는 경우 등
정정·삭제 요구	제36조	사실과 다른 정보의 정정 또는 삭제 요구	다른 법령에서 수집 대상으로 명시된 경우 삭제 요구 불가
처리정지 요구	제37조	처리의 정지 또는 동의 철회 요구	법령상 의무 준수, 계약 이행이 곤란한 경우 등 (사유를 알려야 함)
전송 요구	제35조의2	본인 정보를 본인 또는 다른 처리자에게 전송하도록 요구	컴퓨터 등으로 처리되는 정보 등 법령이 정한 요건 충족 필요

□ 공통 절차

- 요구를 받은 날부터 10일 이내에 필요한 조치를 하고 그 결과를 알려야 함
- **거절하는 경우에는 그 사유와 이의제기 방법을 함께 알려야 함**
- 정정·삭제한 경우 제3자에게 제공한 이력이 있으면 그 사실을 통지
- 권리 행사 창구(열람 청구 접수·처리 부서, 연락처)를 처리방침에 공개해야 함

자동화된 결정에 대한 권리 (제37조의2)

□ 완전히 자동화된 시스템으로 이루어지는 결정 (인공지능 기술을 적용한 시스템 포함)

- 정보주체의 권리 또는 의무에 중대한 영향을 미치는 경우에 적용

거부권	설명 요구권	처리자의 조치 의무
그 결정을 거부할 수 있음 (동의 등에 따른 결정은 제외)	결정에 대한 설명 등을 요구할 수 있음	정당한 사유가 없으면 필요한 조치를 하고 결과를 통지

□ 개인정보처리자의 의무

- 자동화된 결정의 기준과 절차, 개인정보가 처리되는 방식 등을 공개해야 함

적용 사례	자동화된 결정의 내용	정보주체에 미치는 영향
신용 평가	알고리즘이 대출 승인·한도를 자동 결정	금융 거래 기회의 제한
채용 선별	AI 서류 심사로 지원자 자동 탈락	취업 기회의 상실
보험 인수	건강 데이터 기반 인수 거절·보험료 산정	보장 거부, 비용 부담 증가
콘텐츠 제재	자동 필터링에 의한 계정 정지	서비스 이용의 배제

- 「설명 가능성」이 기술 요구사항이 되는 지점 — 모델의 판단 근거를 기록·재현할 수 있어야 함

개인정보처리자의 공개 의무

□ 개인정보 처리방침 (제30조)

- 정보주체가 쉽게 확인할 수 있도록 수립·공개해야 하며, 홈페이지 게재가 원칙
- 포함되어야 할 주요 사항
 - 처리 목적 / 처리·보유 기간 / 제3자 제공 사항 / 위탁 사항 / 파기 절차와 방법
 - 정보주체의 권리·의무와 행사 방법 / 안전성 확보조치 / 개인정보 보호책임자
 - 자동화된 결정에 관한 사항 / 가명정보 처리에 관한 사항 (해당 시)

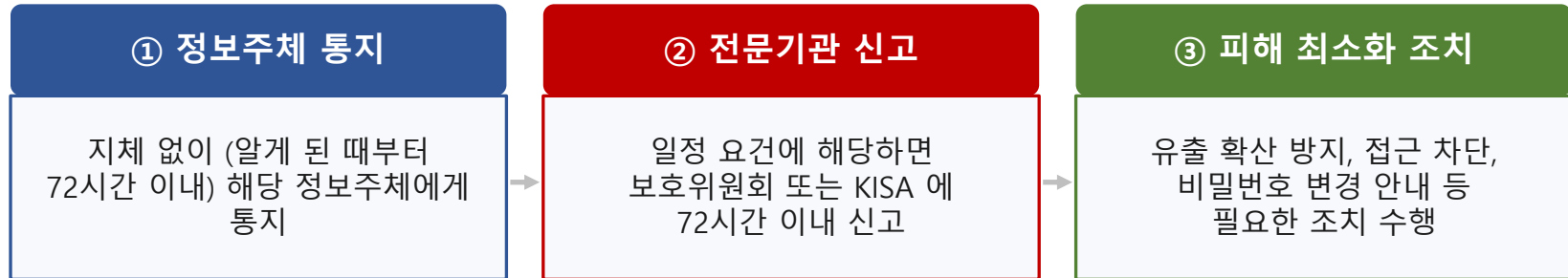
□ 개인정보 보호책임자 (CPO, 제31조)

구분	내용
지정 의무	개인정보 처리에 관한 업무를 총괄해서 책임질 자를 지정 (일정 요건 시 자격요건 적용)
주요 업무	보호 계획 수립·시행, 처리 실태 점검, 불만 처리 및 피해 구제, 내부통제 체계 구축, 처리방침 수립·변경, 파일 보호·관리·감독
독립성	업무 수행과 관련하여 정당한 이유 없이 불이익을 받지 않도록 보장되어야 함
공개	성명·부서·연락처를 처리방침에 공개하여 정보주체가 접촉할 수 있도록 함

- 처리방침은 「법적 문서」이자 「대외 약속」 — 실제 처리 현황과 다르면 그 자체가 위반

유출 통지 · 신고 (제34조)

□ 개인정보가 분실·도난·유출된 사실을 알게 되었을 때의 조치



□ 통지에 포함되어야 할 사항

- ① 유출된 개인정보의 항목 ② 유출된 시점과 그 경위
- ③ 피해를 최소화하기 위하여 정보주체가 할 수 있는 방법 등에 관한 정보
- ④ 개인정보처리자의 대응조치 및 피해 구제절차 ⑤ 담당 부서 및 연락처

신고 대상 (시행령) : 1천 명 이상의 정보주체에 관한 개인정보가 유출된 경우,
민감정보 또는 고유식별정보가 유출된 경우,
외부의 불법적인 접근에 의해 안전성 확보조치를 하지 않아 유출된 경우

- 「유출 사실을 알게 된 때」의 판단이 실무의 핵심
→ 탐지 체계와 로그가 없으면 인지 자체가 늦어짐
- 암호화되어 있어도 통지·신고 의무는 면제되지 않으나,
피해 정도의 판단에 영향을 줄 수 있음

설계 단계의 보호 : Privacy by Design

- 개인정보 보호를 사후 대응이 아니라 시스템 설계 단계에 내재화하는 접근

① 사전 예방 사고가 난 뒤 대응하는 것이 아니라 발생 전에 예방하도록 설계	② 기본값으로서의 보호 이용자가 아무 설정을 하지 않아도 가장 보호적인 상태가 기본값	③ 설계에 내재 부가 기능이 아니라 시스템 구조의 일부로 보호 기능을 포함
④ 완전한 기능성 보안과 기능이 제로섬이 아니라 양립하도록 설계	⑤ 전 생애주기 보호 수집부터 파기까지 전 단계에 걸쳐 보호가 유지	⑥ 가시성과 투명성 처리 방식과 정책을 검증 가능한 형태로 공개

- ⑦ 이용자 프라이버시 존중 : 이용자 중심으로 설계하고 선택권과 통제권을 실질적으로 제공

□ 우리 법에서의 근거

- 제3조④ 위험 정도를 고려한 안전한 관리, 제3조⑥ 사생활 침해 최소화, 제3조⑦ 익명·가명처리
- **GDPR 제25조는 「설계에 의한 데이터 보호」와 「기본설정에 의한 데이터 보호」를 명시적 의무로 규정**

보호 원칙과 암호기술의 대응

보호 원칙	요구되는 상태	대응하는 기술
최소 수집	필요 이상으로 식별 정보를 보유하지 않음	해시 기반 중복 확인, 토큰화, 영지식증명
목적 범위 내 처리	허용된 목적·주체만 접근	접근통제, 키 분리, 속성 기반 암호
정확성·무결성	변조 여부를 검증할 수 있음	해시 함수, 메시지 인증 코드(MAC), 전자서명
안전한 관리	유출되어도 판독 불가	저장 시 암호화(AES), 전송 구간 암호화(TLS)
투명성·책임성	누가 무엇을 했는지 입증 가능	접속기록 무결성 보호, 로그 서명, 타임스탬프
익명·가명처리	식별하지 않고 활용	가명처리, 동형암호, 다자간 연산, 차분 프라이버시
파기	복구 불가능한 삭제	암호키 파기(크립토 셰딩), 매체 파기

법이 정한 「원칙」은 목표이고, 암호기술은 그 목표를 달성하는 「수단」이다
원칙을 모르면 기술을 잘못 고르고, 기술을 모르면 원칙을 지킬 수 없다

원칙을 구현하는 기술 : 사례

□ 사례 1) 회원 중복 가입 확인 — 원본을 보관하지 않고 판단하기

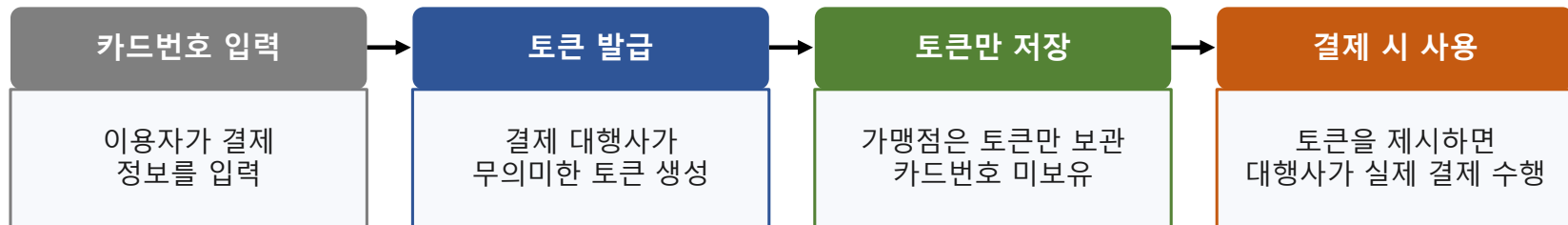
원본 보관 방식

- 주민등록번호를 그대로 저장
- 신규 가입 시 저장된 값과 직접 비교
- 유출 시 전체 값이 그대로 노출
- 법령상 처리 근거 확보 자체가 어려움

해시 기반 방식

- 값에 솔트를 더해 해시값만 저장
- 신규 가입 시 해시값끼리 비교
- 유출되어도 원본 복원이 어려움
- 「동일인 여부」라는 목적만 달성

□ 사례 2) 결제 정보 처리 — 토큰화 (Tokenization)



□ 사례 3) 연령 확인 — 속성만 증명하기

- 생년월일 전체를 수집하는 대신 「만 19세 이상인가」 라는 참·거짓 값만 확인
- 본인확인기관이 연령 조건 충족 여부만 응답하거나, 영지식증명으로 나이를 밝히지 않고 조건 충족을 증명
- **공통 구조** : 목적 달성에 필요한 「최소한의 정보」만 남기고 나머지는 애초에 보유하지 않음

국내법과 GDPR 비교

항목	개인정보 보호법 (한국)	GDPR (EU)
적용 범위	국내 개인정보처리자 (역외 적용 규정 있음)	EU 역내 정보주체를 대상으로 하면 역외 기업도 적용
주된 처리 근거	동의 중심 (계약 이행, 정당한 이익 등 병존)	6가지 적법근거 병렬 (동의를 그중 하나)
정보주체 권리	열람, 정정, 삭제, 처리정지, 전송요구, 자동화 결정 대응	접근, 정정, 삭제(잊힐 권리), 제한, 이동, 반대, 자동화 결정
보호책임자	개인정보 보호책임자(CPO) 지정	데이터보호책임자(DPO) — 일정 요건 시 의무
영향평가	공공기관 대상 개인정보 영향평가(PIA)	고위험 처리 시 DPIA 의무
유출 통지	정보주체 통지 및 요건 해당 시 신고 (72시간 기준)	감독기구 신고 72시간, 고위험 시 정보주체 통지
과징금 상한	전체 매출액의 3% 이하 (위반 무관 매출 제외)	전 세계 연매출 4% 또는 2천만 유로 중 higher

- 해외 서비스를 제공하거나 국외로 개인정보를 이전하는 경우 두 법제를 함께 검토해야 함

위반 시의 제재와 책임

행정 제재	과징금 · 과태료 시정명령 · 공표	위반 사실이 확인되면 사고가 없어도 부과 가능
형사 처벌	징역 또는 벌금 (동의 없는 제공, 부정한 방법 취득 등)	행위자 처벌 및 양벌규정 적용
민사 책임	손해배상 법정손해배상 · 징벌적 손해배상	고의·중과실 유출 시 손해액의 5배 이내 배상 가능
평판 · 사업 손실	이용자 이탈, 신뢰 상실 계약 해지 · 주가 하락	법적 제재보다 큰 실질적 손실이 되는 경우가 많음

- 안전조치 의무 위반은 유출 사고가 발생하지 않았더라도 제재 대상이 될 수 있음

핵심 정리 (1)

개인정보 보호의 근거

- 헌법상 개인정보자기결정권을 구체화한 것이 개인정보 보호법
- 일반법(개인정보 보호법) + 특별법(신용정보법·의료법 등) 구조, 특별법 우선

주요 용어

- 정보주체 / 개인정보처리자(책임 귀속) / 개인정보취급자(지휘·감독 대상) / 수탁자
- 「처리」의 범위는 수집·저장·이용·제공·파기 등 거의 모든 행위를 포함

보호 원칙

- OECD 8원칙 · GDPR 7원칙 · 개인정보 보호법 제3조 8개 항은 동일한 뼈대
- 목적 명확화·최소 수집 → 목적 범위 내 처리 → 정확성 → 안전 관리 → 공개
→ 최소 침해 → 익명·가명 → 책임

적법한 처리 근거

- 처리는 「원칙적 금지, 예외적 허용」
- 수집·이용(제15조 7가지) / 제3자 제공(제17조) / 목적 외(제18조) / 위탁(제26조)
- 동의는 여러 근거 중 하나이며, 자유·구체·고지·명확의 요건을 갖추어야 유효

핵심 정리 (2)

특별 보호 대상

- 민감정보(제23조) · 고유식별정보(제24조)는 별도 동의 또는 법령 근거 필요
- 주민등록번호(제24조의2)는 동의를 받아도 원칙적으로 처리 불가, 암호화 저장 필수
- 만 14세 미만 아동은 법정대리인 동의 + 쉬운 언어 고지

정보주체의 권리

- 알 권리 · 동의 선택권 · 열람(사본)과 전송요구 · 정정·삭제 · 처리정지 · 피해 구제
- 완전히 자동화된 결정에 대한 거부권과 설명 요구권 (제37조의2)
- 요구를 받으면 10일 이내 조치·통지, 거절 시 사유와 이의제기 방법 안내

처리자의 의무

- 처리방침 수립·공개(제30조), 개인정보 보호책임자 지정(제31조)
- 안전조치 의무(제29조), 유출 시 72시간 내 통지·신고(제34조), 목적 달성 시 파기(제21조)

원칙과 기술의 연결

- 최소 수집 → 해시·토큰화·영지식증명 / 안전 관리 → 저장·전송 암호화
- 무결성 → 해시·MAC·전자서명 / 익명·가명 → 가명처리·동형암호·차분 프라이버시
- 파기 → 크립토 셰딩. 원칙은 목표, 암호기술은 그 목표를 달성하는 수단



hank You

E-mail: seyoung@kangwon.ac.kr